

SECURITY RISK ASSESSMENT REPORT

Risk Assessment with NIST Risk Management Framework (RMF) and ISO/IEC 27001 Mapping

Mock information system: MediConnect Patient Portal

Item	Detail
Prepared by	Samiksha Chimote
Track	GRC / Other
Date	30 September 2026
Version	1.0
Framework	NIST SP 800-37 Rev. 2 (RMF), FIPS 199, NIST SP 800-53 Rev. 5, SP 800-53A, SP 800-30; ISO/IEC 27001:2022 (Annex A) mapping

Note: MediConnect is a fictional system created for this exercise. All evidence, test results, names and dates are simulated for demonstration.

1. Scope

1.1 System description

This report applies the NIST Risk Management Framework to MediConnect, a fictional cloud-hosted patient portal that lets patients book appointments, view lab results and request prescription refills. MediConnect is a three-tier web application hosted in a commercial cloud (IaaS) environment. Patients sign in through a web browser or mobile app. Staff use an internal admin console reached over a VPN.

- Components:** Web application firewall (WAF), two application servers, a managed relational database, an object store for lab-result PDFs, an identity provider (IdP), and a SIEM for log collection.
- Data:** Patient profile data, appointment records, lab results and prescription requests (protected health information).
- Users:** Around 40,000 registered patients, 120 clinical staff and 8 system administrators.
- Boundary:** Everything in the production cloud account. Physical and environmental controls are inherited from the cloud provider. The patient's own device is out of scope.

1.2 Approach

The work follows NIST SP 800-37 Rev. 2. The Prepare step (roles, risk tolerance, system boundary) is summarized in Section 1.1, and Implement is represented by the control descriptions in Section 3. Assessment procedures follow SP 800-53A (examine, interview, test). Risks are scored with a qualitative 3×3 method based on SP 800-30. Controls are cross-referenced to ISO/IEC 27001:2022 Annex A.

RMF step	Output in this report
1. Categorize	Information types and FIPS 199 impact levels (Section 1.3)
2. Select	Baseline, tailoring decisions and NIST / ISO 27001 control mapping (Section 3)
3. Assess	Assessment results and findings (Section 4), risk register with residual ratings (Section 2)
4. Authorize	Authorization recommendation, decision memo and POA&M (Sections 5.1 and 5.2)
5. Monitor	Continuous monitoring plan and reauthorization triggers (Section 5.3)

1.3 System categorization (FIPS 199)

Information types were identified with reference to NIST SP 800-60 and rated for the impact of a loss of confidentiality (C), integrity (I) or availability (A). Impact levels follow FIPS 199: Low, Moderate or High.

Information type	C	I	A	Rationale
Patient health records and lab results	Moderate	Moderate	Low	Disclosure would seriously harm patients and trigger breach obligations. Altered results could affect care. A short outage delays access but does not endanger care.

Information type	C	I	A	Rationale
Authentication data (credentials, tokens, sessions)	Moderate	Moderate	Moderate	Compromise enables account takeover. Loss of the IdP blocks all sign-ins.
Appointment scheduling data	Low	Low	Low	Limited sensitivity. Staff can fall back to phone scheduling.
Audit logs	Low	Moderate	Low	Needs tamper protection so that investigations can be trusted.

System categorization (high-water mark): SC MediConnect = {(C, Moderate), (I, Moderate), (A, Moderate)}. The overall impact level is **Moderate**.

Security objective	Impact	Justification
Confidentiality	Moderate	Highest value across information types is Moderate, driven by PHI and authentication data.
Integrity	Moderate	Result and prescription-request accuracy has patient-safety implications.
Availability	Moderate	Authentication data is rated Moderate for availability, so the high-water mark makes system availability Moderate even though patient records alone are Low.

2. Risk Assessment

Risk is scored as likelihood × impact, each on a 1 to 3 scale (Low = 1, Moderate = 2, High = 3). A score of 1 to 2 is Low, 3 to 4 is Moderate and 6 to 9 is High.

Level	Likelihood definition	Impact definition
Low (1)	Threat is unlikely, or existing controls make exploitation very difficult.	Limited effect on a small number of records or a brief, tolerable disruption.
Moderate (2)	Threat is plausible and controls only partly reduce the chance.	Serious effect on patients or operations, such as one patient's PHI exposed or a multi-hour outage.
High (3)	Threat is likely within a year, or a known weakness is easy to exploit.	Severe or widespread harm, such as bulk PHI breach, regulatory action or a prolonged outage.

Likelihood \ Impact	Low (1)	Moderate (2)	High (3)
High (3)	Moderate (3)	High (6)	High (9)
Moderate (2)	Low (2)	Moderate (4)	High (6)
Low (1)	Low (1)	Low (2)	Moderate (3)

Terms. Inherent risk is the level with no controls in place. Residual risk (current) is what remains with the controls as assessed today. Target residual risk is expected once the POA&M items are complete.

Risk register

ID	Risk (threat and weakness)	Finding / control	Inherent	Residual (current)	Target residual	Treatment
R-01	An external attacker exploits an unpatched vulnerability on an internet-facing server and reaches patient data.	F-01 SI-2	High (3×3=9)	High (2×3=6)	Moderate (1×3=3)	Mitigate: automated patching pipeline, 15-day critical SLA tracked on a dashboard, emergency change process.
R-02	Attackers take over patient accounts using stolen or reused passwords and view PHI.	F-05 IA-2(2)	High (3×3=9)	Moderate (2×2=4)	Low (1×2=2)	Mitigate: make MFA mandatory for all patients, with a phased roll-out and support for those without smartphones.
R-03	An insider or attacker uses an orphaned or over-privileged account to access or change data.	F-04 AC-2	High (2×3=6)	Moderate (2×2=4)	Low (1×2=2)	Mitigate: disable orphaned accounts now, link HR leaver feed to the IdP, run quarterly recertification.
R-04	Malicious activity goes unnoticed because logs are not regularly reviewed, delaying breach detection.	F-02 AU-6	High (2×3=6)	Moderate (2×2=4)	Low (1×2=2)	Mitigate: weekly review procedure, use-case-based SIEM reports, review sign-off.

ID	Risk (threat and weakness)	Finding / control	Inherent	Residual (current)	Target residual	Treatment
R-05	Ransomware or a failure destroys data and the untested backups cannot be restored in time.	F-03 CP-9	High (2×3=6)	Moderate (2×2=4)	Low (1×2=2)	Mitigate: quarterly restore test, documented recovery time objective, immutable backup copy.
R-06	Configuration drift leaves two servers with weak settings that widen the attack surface.	F-06 CM-6	Moderate (2×2=4)	Low (2×1=2)	Low (1×1=1)	Mitigate: rebuild from hardened image and enforce drift detection in the compliance scan.

Overall residual risk: Moderate. One risk (R-01) is currently High and is treated as a condition of authorization. After remediation, the target profile is 1 Moderate and 5 Low.

3. Control Mapping [ISO 27001 / NIST]

3.1 Baseline and tailoring

Because the system is categorized Moderate, the NIST SP 800-53 Rev. 5 Moderate baseline was selected as the starting point and then tailored to fit the system.

Tailoring action	Application	Rationale
Scoping	Physical and environmental (PE) controls not applied directly.	No on-premises facility. Inherited from the cloud provider.
Common / inherited controls	PE family, parts of MP and CP-6 (alternate site) inherited from the provider and reviewed annually via the provider's attestation.	Avoids duplicate effort while keeping a documented responsibility split.
Parameterization	Password minimum 14 characters. Session timeout 15 minutes. Critical patches within 15 days, high within 30 days. Log review weekly.	Values reflect the organization's risk tolerance for PHI.
Supplementation	Enhanced database activity monitoring added under AU-2 and SI-4.	PHI sensitivity and insider-threat concerns justify more than the baseline.

3.2 Control mapping

The table maps 20 representative NIST SP 800-53 Rev. 5 controls to their closest ISO/IEC 27001:2022 Annex A controls, how MediConnect implements them, and the result of assessment (Section 4). The ISO mapping is indicative: one NIST control can support several Annex A controls and the reverse.

NIST control	Title	ISO/IEC 27001:2022 Annex A	Implementation and evidence	Result
AC-2	Account Management	A.5.16 Identity management A.5.18 Access rights	Accounts provisioned through IdP with manager approval. Quarterly access reviews required by policy but not performed for admin accounts; 3 orphaned accounts found.	Other than satisfied (F-04)
AC-3	Access Enforcement	A.5.15 Access control A.8.3 Information access restriction	Role-based access control in the application and database. Test users could not access data outside their role.	Satisfied
AC-6	Least Privilege	A.8.2 Privileged access rights A.5.15 Access control	Separate admin and standard roles. Database admin rights limited to 3 named engineers.	Satisfied
AC-17	Remote Access	A.6.7 Remote working A.8.20 Networks security	Admin access only via VPN with MFA. Configuration reviewed.	Satisfied
AT-2	Literacy Training	A.6.3 Information security awareness, education and training	Annual security and privacy training. 96% completion.	Satisfied
AU-2	Event Logging	A.8.15 Logging	Authentication, data access and admin actions logged, including database activity.	Satisfied
AU-6	Audit Record Review	A.8.15 Logging A.8.16 Monitoring activities	Logs sent to SIEM with alert rules, but no scheduled human review. Reviews are ad hoc.	Other than satisfied (F-02)

NIST control	Title	ISO/IEC 27001:2022 Annex A	Implementation and evidence	Result
CA-7	Continuous Monitoring	A.5.36 Compliance with policies, rules and standards A.8.16 Monitoring activities	Monitoring strategy defined and documented (Section 5.3).	Satisfied
CM-2	Baseline Configuration	A.8.9 Configuration management	Hardened server images kept under version control.	Satisfied
CM-6	Configuration Settings	A.8.9 Configuration management	Automated compliance scan shows 2 of 10 servers deviating from the baseline (weak TLS cipher, unused service enabled).	Other than satisfied (F-06)
CP-9	System Backup	A.8.13 Information backup	Daily encrypted database backups and versioned object storage. Restore has never been tested.	Other than satisfied (F-03)
IA-2(1),(2)	Multi-Factor Authentication	A.8.5 Secure authentication	MFA enforced for staff and admins. MFA is optional for patient accounts (22% enrolled).	Other than satisfied (F-05)
IA-5	Authenticator Management	A.5.17 Authentication information A.8.5 Secure authentication	Password policy enforced, lockout after 5 failures, breached-password check at set time.	Satisfied
IR-4	Incident Handling	A.5.26 Response to information security incidents A.5.24 Incident management planning and preparation	Incident response plan with defined roles. Tabletop exercise completed in the last 6 months.	Satisfied
RA-5	Vulnerability Monitoring	A.8.8 Management of technical vulnerabilities	Weekly authenticated scans of servers and monthly web application scans.	Satisfied
SC-7	Boundary Protection	A.8.20 Networks security A.8.22 Segregation of networks	WAF in front of the application. Network segmentation between web, app and database tiers.	Satisfied
SC-8	Transmission Confidentiality	A.8.24 Use of cryptography A.5.14 Information transfer	TLS 1.2 or higher enforced externally and internally.	Satisfied
SC-28	Protection at Rest	A.8.24 Use of cryptography	AES-256 encryption for database, object store and backups, with managed keys.	Satisfied
SI-2	Flaw Remediation	A.8.8 Management of technical vulnerabilities	Critical patches on internet-facing servers took 38 days on average against the 15-day requirement (sample of 6 patches).	Other than satisfied (F-01)
SI-4	System Monitoring	A.8.16 Monitoring activities	SIEM correlation rules and intrusion detection alerts reviewed by the on-call analyst.	Satisfied

4. Findings

Each control was assessed using the three SP 800-53A methods. Documents such as policies and configurations were examined. System owners and administrators were interviewed. Controls were tested by sampling patch records, running configuration scans, and attempting access as different roles.

Controls assessed	Satisfied	Other than satisfied	Findings raised
20	14	6	6 (1 High, 4 Moderate, 1 Low)

A finding's severity reflects the weakness itself. Risk is rated separately in Section 2.

ID	Control (NIST / ISO 27001)	Finding	Severity	Method	Linked risk
F-01	SI-2 A.8.8	Critical patches on internet-facing servers not applied within the 15-day requirement (38-day average).	High	Examine patch records; test scan results	R-01
F-02	AU-6 A.8.15, A.8.16	No scheduled log review process. Alerts are handled but log patterns are not reviewed.	Moderate	Examine procedures; interview SOC lead	R-04

ID	Control (NIST / ISO 27001)	Finding	Severity	Method	Linked risk
F-03	CP-9 A.8.13	Backup restore has never been tested, so recovery time and data integrity are unverified.	Moderate	Examine backup jobs; interview DBA	R-05
F-04	AC-2 A.5.16, A.5.18	Admin access reviews not performed. Three accounts belonging to former staff remain active.	Moderate	Examine account list; test HR leaver report	R-03
F-05	IA-2(2) A.8.5	MFA optional for patient accounts, leaving them exposed to credential stuffing.	Moderate	Examine IdP config; test sign-in flow	R-02
F-06	CM-6 A.8.9	Two of ten servers deviate from the hardened baseline.	Low	Test automated compliance scan	R-06

5. Recommendations

5.1 Remediation plan (POA&M)

The actions below close each finding. Each has an owner and a due date, and they are ordered by priority.

ID	Action	Owner	Due	Priority
F-01	Automate patching of internet-facing servers, clear the current backlog and track the 15-day SLA on a dashboard.	Infrastructure lead	30 Nov 2026	High
F-04	Disable the 3 orphaned accounts immediately. Integrate the HR leaver feed with the IdP and perform the first admin access review.	IAM manager	31 Oct 2026	Moderate
F-02	Publish the weekly log review procedure and assign reviewers.	SOC lead	15 Nov 2026	Moderate
F-03	Perform a full restore test, record the recovery time, and add an immutable backup copy.	Database administrator	15 Dec 2026	Moderate
F-05	Make MFA mandatory for patients with phased roll-out and support.	Product owner	31 Jan 2027	Moderate
F-06	Rebuild the 2 non-compliant servers and enable drift alerts.	Infrastructure lead	31 Oct 2026	Low

5.2 Authorization recommendation

The Authorizing Official (AO) makes a risk-based decision after reviewing the assessment results, the risk register and the POA&M. The recommendation is a **Conditional Authorization to Operate (ATO) for 12 months**.

Item	Decision
System	MediConnect Patient Portal (Moderate)
Decision	Conditional Authorization to Operate (ATO)
Term	12 months, until 30 September 2027, or until a significant change or event triggers earlier review
Overall residual risk	Moderate, judged acceptable given the strong baseline controls (14 of 20 satisfied) and a funded remediation plan
Condition 1	Close F-01 (patching) within 60 days, by 30 November 2026. If missed, the AO reviews whether the ATO continues.
Condition 2	Report POA&M status to the AO monthly until all items are closed.
Condition 3	Implement mandatory MFA for patients (F-05) by 31 January 2027.
Rationale	The High-rated weakness has a clear fix and short timeline. The remaining risks are Moderate or Low, and no weakness allows unauthenticated bulk access to patient data.

Role	Name	Signature	Date
Authorizing Official (CIO)	[Name]		
System Owner	[Name]		
Information System Security Officer	[Name]		
Security Control Assessor	Samiksha Chimote		

5.3 Continuous monitoring and reauthorization triggers

Continuous monitoring keeps the risk picture current between assessments. The activities below cover the controls that failed assessment and the controls whose risk changes fastest.

Activity	Control	Frequency	Owner	Metric or trigger
Authenticated vulnerability scanning	RA-5	Weekly	Security engineer	New critical or high findings; time to remediate
Patch compliance reporting	SI-2	Monthly	Infrastructure lead	% of critical patches within 15 days (target 100%)
Log review	AU-6	Weekly	SOC lead	Review completed and signed off
Access recertification	AC-2	Quarterly	IAM manager	Orphaned accounts (target 0)
Backup restore test	CP-9	Quarterly	Database administrator	Restore success and recovery time
Configuration compliance scan	CM-6	Monthly	Infrastructure lead	% of servers matching baseline
Patient MFA adoption	IA-2(2)	Monthly	Product owner	% of patient accounts with MFA
Incident response exercise	IR-4	Every 6 months	Security manager	Lessons learned tracked to closure
POA&M and risk register review	CA-5, RA-3	Monthly / quarterly	ISSO	Overdue items; change in residual ratings
Annual control reassessment	CA-2	Annually	Independent assessor	Findings vs. prior year

Reauthorization triggers

- A major architecture or hosting change, or a new interface exposing patient data.
- A security incident involving PHI, or a new critical vulnerability with no mitigation.
- A missed condition of the ATO, such as F-01 not closed by 30 November 2026.
- Expiry of the ATO term, or a significant change in the threat landscape or regulations.

5.4 Conclusion

MediConnect has a solid Moderate-baseline foundation: 14 of the 20 assessed controls are fully satisfied, including encryption, boundary protection and incident response. The main gaps are operational, not architectural: patching speed, access review, log review, backup testing, patient MFA and configuration drift. Each gap has an owner and a due date. With the POA&M complete, residual risk falls from Moderate overall (with one High item) to mostly Low. Authorizing the system conditionally is a reasonable decision, as long as the monitoring plan in Section 5.3 is followed.

References

- NIST SP 800-37 Rev. 2, Risk Management Framework for Information Systems and Organizations
- FIPS 199, Standards for Security Categorization of Federal Information and Information Systems
- NIST SP 800-60, Guide for Mapping Types of Information and Systems to Security Categories
- NIST SP 800-53 Rev. 5, Security and Privacy Controls; SP 800-53A Rev. 5, Assessing Security and Privacy Controls
- NIST SP 800-30 Rev. 1, Guide for Conducting Risk Assessments
- ISO/IEC 27001:2022, Information security management systems, Annex A (control mapping in Section 3)